LLM-Driven Adaptive Authentication and Access Control in Zero Trust Systems Using Blockchain

Parth Kansal*, Anshul Sharma*, Vireshwar Singh Tomar*
*Department of Computer Science Engineering (Information Security)
Chandigarh University, Mohali, Punjab, India
Email: parth.kansal823@gmail.com, anshul08062005@gmail.com, vireshwartomar333@gmail.com

***Abstract*—Traditional Identity and Access Management (IAM) systems use static rules that remains same regardless of context. For example, a user who logs in from a recognized device at a normal hour goes through the same authentication process as someone logging in from an unfamiliar machine from a foreign country at an unusual time. With the known vulnerabilities of centralized credential storage, this leaves organizations exposed to credential theft, insider misuse, and unauthorized access on a scale that static defenses are never meant to address. This paper propose an adaptive IAM framework which follow Zero Trust principles. This framework integrates machine learning based risk scoring, large language model(LLM) to assist authorization, natural language processing to validate requests, and blockchain to make tamper proof audit logging. During authentication, the system computes risk score from contextual and behavioral features in real time, then applies adaptive security measures. During authorization, the system evaluates user provided justifications, routing uncertain requests to human reviewers selected by an LLM based on organizational context. All events are immutably recorded on a blockchain and smart contracts which let us enforce time limited access grants that auto revoke upon expiry. The expected performance analysis, based on benchmarks from comparable published systems, projects to be 85–92% accuracy in risk scoring, latency of less than 200 ms, and 83–89% accuracy in NLP classification. To the best of our knowledge, no existing system brings adaptive risk scoring, NLP based request validation, LLM assisted human in the loop governance, and blockchain audit logging in a single unified IAM framework together.**

***Index Terms*—adaptive authentication, zero trust architecture, blockchain, large language models, risk-based access control, identity and access management, smart contracts, NLP validation, decentralized audit logging**

I. Introduction

There is a recurring pattern in recent cyber incidents that deserves attention. The attackers obtain valid credentials through phishing, credential stuffing, or from a prior breach. The target organization's authentication mechanism has no way of telling that user logginf into the system is not real. The correct password was entered, access was granted, and no further verification is performed [1].

This outcome reflects an fundamental weakness to static authentication. The mechanism poses one question: Does the requester possess the correct secret? If the answer is yes, the system grants access. There is no further evaluation of whether the login attempt matches the user's established patterns, no consideration of geographic or device anomalies, and system have no path to invoke suspicious but credential valid sessions to additional verification [1], [3]. The system was built for a threat landscape that has since changed beyond recognition.

Authorization mechanisms suffer with parallel problem. Access permissions in most of the deployed systems are bound to role definitions that may not been revisited for months or years. When an employee needs temporary access to a resource outside their scope, like, an marketing analyst needs a financial report of a client, this process generally involves a manual request which gives an uncertain waiting period and also there is an probability that the temporary access will persist beyond its intended duration because revoking the access depends on someone remembering to revoke it [2].

Centralized credential storage worsens both of these issues. A single database holds identity data for all users in an organization. Thus, this system is the highest valuable target for the attacker. If attackers compromises it, the entire user data is exposed. In recent years this was the main reason for the data breaches [4], [5].

These observations clearly suggest a requirement for a next generation authentication and authorization system. This system should compute the risk in real time with dynamic rules. The system should calibrate authentication challenges according to assessed risk level. The system should bring intelligent evaluation to authorization decisions that exceed the capacity of simple role based checks. It should maintain an audit trail resistant to post hoc modification. And it should accomplish all of this without burdening legitimate users with excessive friction, since friction drives workaround behavior that undermines security [6].

The framework proposed in the paper addresses these requirements by integrating three complementary technologies. Machine learning models analyze behavioral and contextual features to produce real-time risk scores. Large language models provide the contextual reasoning needed to select appropriate human reviewers for ambiguous authorization decisions and to evaluate natural language justifications for access requests. Blockchain technology provides an append only, cryptographically chained ledger that records every event, access decision, and vote [5], [7].

It should be noted that the framework presented here is a proposed design. We describe the architecture, methodology, and expected performance characteristics derived from published benchmarks of comparable individual components. Full-scale implementation and empirical validation on production

data are planned as future work. We consider this approach justified because each component – ML risk scoring, NLP classification, blockchain logging, voting mechanisms has been independently validated in prior literature, and the contribution of this work lies in their integration into a coherent pipeline that addresses gaps no existing system covers.

The remainder of this paper is organized as follows. Section II surveys related work. Section III details the proposed methodology, including mathematical formulations for risk scoring, anomaly detection, and voting consensus. Section IV presents the system architecture. Section V analyzes expected performance. Section VI discusses contributions, limitations, and comparisons with existing approaches. Section VII concludes with future research directions.

II. Related Works

A. Risk-Based Authentication

Risk based authentication replaces the uniform challenge model with a score driven approach. Contextual signals from each login attempt are feeded into a classifier and the resulting risk score determines the level of verification to be put [1], [3].

Wiefling et al. conducted an study on this topic where he analyzed 31 million login events gathered from 3.3 million users in the duration of twelve months. The results demonstrated that machine learning optimization of risk parameters yields measurable improvements in the security usability trade off. They also released a synthesized login dataset that is taken as the standard benchmark for the research community [3], [8].

Picard and Pierre implemented reinforcement learning approach in RLAuth, where the agent dynamically selects authentication challenges based on contextual features. On the CRAWDAD Telefonica smartphone dataset, they achieved a geometric mean accuracy of 92.6%, which was more from conventional classifiers [9]. Fereidouni et al. proposed F-RBA (federated learning framework). There model trains risk models locally on user devices which help preserving the users data privacy while achieving improved true positive rates over traditional anomaly detection methods [10].

B. Continuous and Behavioral Authentication

Continuous authentication extends identity verification beyond the login event to cover entire sessions. Baig and Eskeland provide a comprehensive survey covering keystroke dynamics, mouse movement analysis, and sensor-based mobile biometrics [11]. Frank et al. demonstrated with Touchalytics that touchscreen interaction patterns carry sufficient identity signal to distinguish between users [12]. These methods offer a natural advantage to risk based authentication, though the tension between security benefits and user privacy remains a central challenge.

C. Zero Trust and Trust Scoring

Zero Trust, formulated by Kindervag in 2010 and formalized by NIST in Special Publication 800-207, works on the principle that no user or device should receive implicit trust regardless of network location [7], [13]. Wang et al. applied this philosophy to Internet of Vehicles environments through AU-ZTAC, computing dynamic trust scores from user behavior and various attributes [14]. Google's BeyondCorp initiative demonstrated the viability of perimeterless enterprise security at scale [15].

D. Blockchain-Based Access Control

Blockchain addresses the log integrity problem that plagues centralized databases. Cryptographic hash chaining ensures that any modification to a previous log entry invalidates all subsequent entries. Hu et al. built N-Accesses on Ethereum, using smart contract to enforce time limited access with immutable event logging [16]. Tawfik et al. developed ACHealthChain on Hyperledger Fabric, which achieved approx 19.7% throughput improvement and 87% reduction in latency compared to earlier blockchain based access control systems [18]. Yaqub et al. applied blockchain to GDPR-compliant healthcare consent management [17].

E. LLMs in Access Control

Zisad proposed LLMAC, a framework unifying RBAC, ABAC, and DAC under a single LLM, achieving 98.5% accuracy on synthetic policy scenarios while generating human readable justifications for each decision [19]. The interpretability dimension is significant given that opacity in automated security decisions remains a known barrier to enterprise adoption.

F. Research Gaps

Each surveyed thread addresses a subset of IAM challenges, but none delivers the complete picture. RBA research terminates at the login event and does not address what happens when an authenticated user requests access to a resource outside their normal permissions. Blockchain based system provide strong integrity for audit logs, yet they rely on static smart contract rules and do not provide any form of adaptive, context aware decision making. LLM based access control looks promising in early evaluations but largely remains theoretical and has not been integrated into the functioning authentication and authorization pipeline with real time risk assessment. Also, none of the systems address the authorization justification problem. The fact that most organizations collect free text reasons for access requests but never analyzed them programmatically. This represents a significant missed opportunity for catching social engineering attempts and policy violations at the point of request rather than after the damage is done.

No published system, to our knowledge, combines adaptive ML based risk scoring, NLP driven request justification validation, LLM assisted human in the loop voter selection, and blockchain based immutable audit logging within a single unified framework. Table I summarizes these capability gaps across the surveyed systems. This gap constitutes the primary motivation for the present work.

TABLE I
CAPABILITY COMPARISON: EXISTING SYSTEMS VS. PROPOSED FRAMEWORK

System	Focus	Adpt.	BC	NLP	Vote
Wiefling [3]	Empirical RBA	Yes	No	No	No
RLAuth [9]	RL-based RBA	Yes	No	No	No
F-RBA [10]	Federated RBA	Yes	No	No	No
N-Access [16]	IoT AC	No	Yes	No	No
ACHealth [18]	Healthcare AC	No	Yes	No	No
LLMAC [19]	LLM-based AC	Part.	No	No	No
Proposed	**Unified IAM**	**Yes**	**Yes**	**Yes**	**Yes**

III. PROPOSED METHODOLOGY

A. System Overview

The framework is made by two interconnected pipelines. The authentication pipeline computes dynamic risk score from contextual and behavioral features in real time and apply security challenges based on the assessed risk tier. The authorization pipeline evaluates resource access requests through NLP based analysis and when justified it routes decisions to human reviewers who are intelligently selected by LLM. Both pipelines share a common blockchain audit layer that maintains an immutable record of every event.

B. Machine Learning-Based Risk Scoring

1) Feature Engineering: The risk model ingests features organized into five categories:

- **User Context Parameters:** Login time, day of week, IP address, geographic location (derived from IP), device type, operating system and browser.
- **Behavioral Parameters:** Average login hours, standard deviation from that average, login frequency across configurable time windows, count of recent failed attempts, typical session duration, and optionally keystroke timing as a soft biometric.
- **Device and Network Trust:** Whether the device and IP address have been seen before, VPN or proxy usage flagging and device switching frequency over a rolling one week window.
- **Historical Risk Parameters:** Prior risk scores, cumulative suspicious activity count, time elapsed since last login, account age, and the user's organizational role.
- **Access Request Parameters:** Resource sensitivity classification and the NLP assessed validity of the user-stated justification (applicable during authorization requests only).

2) Risk Score Computation: Let $X = \{x_1, x_2, \ldots, x_n\}$ denote the feature vector for a given login attempt. The trained model computes a scalar risk score $S = f(X) \in [0, 1]$, interpreted as the estimated probability $P(\text{suspicious} \mid X)$.

TABLE II
INPUT FEATURE CATEGORIES AND REPRESENTATIVE VALUES

Category	Key Parameters	Type	Example
User Context	Login time, IP, location	Real-time	08:23, Giddarbaha
Behavioral	Frequency, failures	Historical	3 failures / 1 hr
Device Trust	Known device, VPN flag	Boolean	Unknown + VPN
Historical	Past scores, account age	Float/int	S=0.12, 2 years
Access Req.	Resource, sensitivity	Categorical	HR doc, confid.

The model employ a two stage ensemble combining logistic regression for baseline probability estimation and random forest for capturing non-linear feature interactions. The final score is computed as:

$$S = \alpha \cdot S_{LR} + (1 - \alpha) \cdot S_{RF} \tag{1}$$

where S_{LR} is the logistic regression probability output, S_{RF} is the random forest probability, and $\alpha = 0.4$ is the blending weight selected based on configurations reported in comparable RBA studies [3], [9]. These classifiers were selected over deep neural alternatives because the accuracy differential reported in comparable studies is marginal (typically 1–3 percentage points), whereas inference latency is approximately 4x lower which is critical consideration for authentication system [20].

Model parameters θ is optimized by minimizing binary cross entropy loss over the labeled training set:

$$L(\theta) = -\frac{1}{m} \sum_{i=1}^{m} [y_i \log(f_\theta(X_i)) + (1 - y_i) \log(1 - f_\theta(X_i))] \tag{2}$$

where m is the number of training samples and $y_i \in \{0, 1\}$ indicates legitimate (0) or suspicious (1) login behavior.

Anomaly detection is performed by computing the Mahalanobis distance of the current feature vector from the user's established baseline:

$$d(X) = \sqrt{(X - \mu)^T \Sigma^{-1} (X - \mu)} \tag{3}$$

where μ is the mean feature vector and Σ is the covariance matrix of the user's historical login data. A larger Mahalanobis distance indicates greater deviation from normal behavior and contributes higher risk signal to overall score S.

The continuous score is discretized into three tiers:

$$\text{Category}(S) = \begin{cases} \text{Low}, & \text{if } S < 0.3 \\ \text{Medium}, & \text{if } 0.3 \leq S < 0.7 \\ \text{High}, & \text{if } S \geq 0.7 \end{cases} \tag{4}$$

$$A = g(S) = \begin{cases} \text{Allow}, & \text{if Low} \\ \text{MFA/biometrics}, & \text{if Medium} \\ \text{Honeypot}, & \text{if High and credentials valid} \\ \text{Block}, & \text{if High} \end{cases} \tag{5}$$

These thresholds are to be configurable by admin to align the model with organizational risk tolerance.

3) Adaptive Authentication Mechanism: Low-risk logins proceed with direct access. Medium-risk logins triggersecondary verification, typically an OTP delivered to the registered device. High-risk logins result in strict multi-factor verification or access denial with administrator notification. A special case arises when risk score exceeds 0.85 but the credentials are correct. In this case it strongly suggests that the credentials got stolen. Rather than blocking, the system redirects such sessions into a honeypot environment containing synthetic data. The honeypot mirrors the real systems interface and file structure, but all data inside is fabricated. It runs in an isolated containers with zero lateral movement to actual systems, and sessions is limit to 30 to 60 minutes. Everything the attacker does inside the honeypot is been recorded such as pages visited, files opened, search queries, commands executed. This provides threat intelligence about attacker objectives and methods that informs better placement of real security controls [23].

The model is to undergo with periodic retraining on data that is been accumulated, incorporating confirmed outcomes and voting decisions to maintain alignment with evolving user patterns and emerging attack techniques.

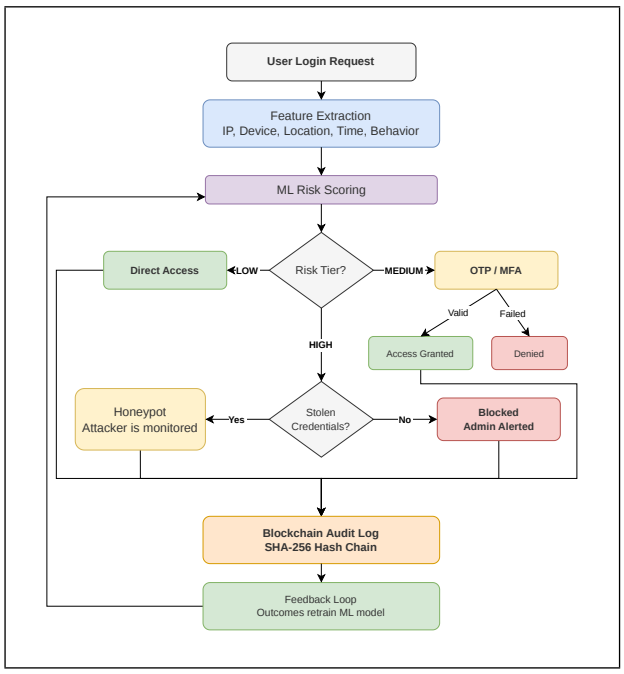


Fig. 1. Adaptive authentication pipeline with honeypot deception.

C. NLP-Based Request Justification Validation

A notable weakness in current authorization workflows is that access request justifications is typically collected as free text input which are recorded but rarely evaluated through a code/program. The proposed framework addresses this through a two-tier NLP classification pipeline.

The preprocessing stage applies tokenization, stop word removal, and lemmatization using spaCy. The cleaned text is converted to a numerical feature representation via TF-IDF vectorization with a vocabulary size capped to 5,000 features. The primary classifier is a multinomial naive bayes model, selected for its computational efficiency and established effectiveness in text classification. For cases where the primary model's probability falls below a confidence threshold β, a fine-tuned BERT model (`bert-base-uncased` from HuggingFace Transformers) provides secondary classification. The posterior is computed using Bayes theorem:

$$P(\text{suspicious} \mid \text{text}) = \frac{P(\text{text} \mid \text{suspicious}) \cdot P(\text{suspicious})}{P(\text{text})} \tag{6}$$

When this posterior falls below $\beta = 0.65$, the BERT model is invoked to reduce misclassification risk on ambiguous inputs. The BERT model processes the raw justification text through 12 transformer layers and produces a binary classification with its own confidence score. If both models disagree, the higher-confidence prediction is selected.

The training data consists of 2,000 synthetic justification samples representing both legitimate and suspicious request patterns, with a 60-40 split. Legitimate samples include specific project references and deadline mentions. Suspicious samples contain vague phrasing, urgency without specificity, and patterns associated with social engineering. Based on published benchmarks for TF-IDF + Naive Bayes text classification in security-adjacent domains, the primary classifier is to achieve approx 83% accuracy, with precision of $\sim$0.81 and recall of $\sim$0.85 for the suspicious class. BERT fallback is expected to raise combined accuracy to approx 89%.

D. LLM-Assisted Voting-Based Authorization

When either the risk score exceeds a threshold or NLP module flags the justification, the system escalates the access request to human reviewers. Rather than routing all requests to a generic admin pool, the framework uses an LLM to select appropriate reviewers. The LLM analyzes the resource type, sensitivity classification, requesting users department, and organizational hierarchy to identify individuals best positioned to evaluate the request.

Selected reviewers receives a decision packet which contains the requester identity, target resource, computed risk score, relevant anomaly indicators, NLP assessment of the justification, and a summary of recent access history. Each reviewer casts a vote through dashboard. The system applies weighted majority voting:

$$D_{\text{final}} = \begin{cases} \text{Approve}, & \text{if } \sum w_i \cdot v_i > 0.5 \cdot \sum w_i \\ \text{Deny}, & \text{otherwise} \end{cases} \tag{7}$$

where $v_i \in \{0, 1\}$ is the vote of reviewer i (1 = approve) and w_i is the assigned weight (1.5 for resource owners, 1.0 for others). Voting confidence is measured as $C = \sum w_i v_i / \sum w_i$. A configurable timeout (default is 48 hours) triggers a deny by default fallback. If only a partial set of reviewers responds

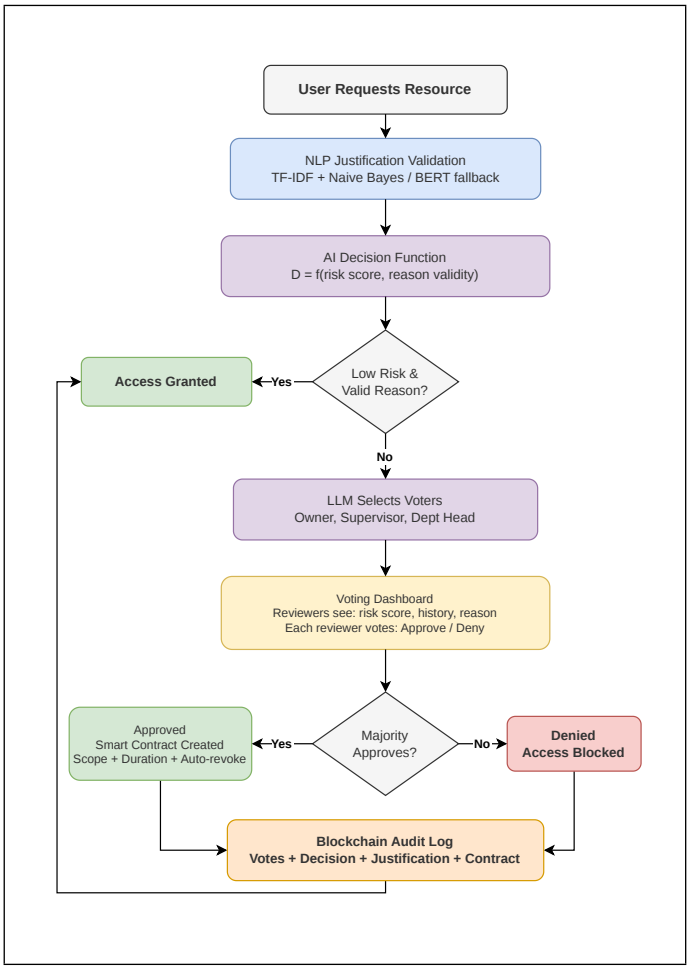


Fig. 2. Authorization pipeline with NLP validation and LLM-assisted voting.

before timeout, the system computes the decision from available votes only, provided at least two votes have been cast. Single-vote decisions is not permitted.

Voting outcomes are sent back into the ML model as newly labeled training instance which creates an active learning loop:

$$\theta^* = \arg\min_{\theta} \sum_i L(f_\theta(X_i), y_i) + \lambda \cdot \sum_j L(f_\theta(X_j), D_{\text{vote}_j}) \tag{8}$$

where the first term is the standard training loss and the second term incorporates voting-derived labels weighted by λ. This formulation ensures the model progressively adapts to patterns that human reviewers identify as legitimate or suspicious, reducing future escalation volume.

E. Blockchain-Based Audit and Trust Mechanism

The framework records every significant event as a block in a permissioned blockchain. Each block B_i contains event data, timestamp, and SHA-256 hash of the preceding block:

$$H_i = \text{SHA-256}(\text{uid} \| \text{ts} \| \text{event} \| \text{score} \| \text{action} \| H_{i-1}) \tag{9}$$

$$B_i = \{D_i,\ T_i,\ H_{i-1},\ H_i\} \tag{10}$$

Events recorded event includes successful and failed login attempts, risk scores with feature breakdowns, access request submissions, NLP classification results, individual votes with timestamps, final decisions, smart contract creation, and access revocations. Any modification to block B_j (where $j < i$) produces different H_j, causing a mismatch in all subsequent blocks that can is easily detected through a linear-time chain verification scan.

For access grants approved through voting, smart contracts is created which encode the access policy by granted resource, permission scope, duration, and conditional constraints. Upon expiry or any constraint violates, the contract triggers automatic revoke. This eliminates the well documented problem of temporary permissions persisting.

The blockchain is implemented as a lightweight permissioned chain, avoiding the computational overhead of proof-of-work consensus while retaining the integrity needed for enterprise audit compliance.

F. Threat Model and Security Assumptions

The framework addresses the following primary adversarial scenarios:

- **Credential theft:** Detected through contextual mismatch between the attacker's access patterns and the legitimate user's baseline.
- **Insider threats:** Mitigated by routing unusual access requests through voting.
- **Privilege escalation:** Made traceable through the blockchain audit trail.
- **Log tampering:** Prevented by hash-chain integrity verification.

TABLE III
THREAT SCENARIOS AND FRAMEWORK RESPONSES

Threat	Detection	Response
Credential theft	ML context mismatch	Block / MFA
Insider threat	Unusual access pattern	Voting escalation
Privilege escalation	Blockchain audit	Trail + alert
Log tampering	Hash-chain verify	Immediate detection
Stolen credentials	S $>$ 0.85 + valid pwd	Honeypot redirect

The design assumes TLS encrypted communication between client and server, the blockchain nodes are not been simultaneously compromised, and that training data is reasonably representative of both legitimate and malicious login patterns. The honeypot environment is assumed to be fully isolated with no path to production data.

IV. System Architecture and Design

A. Architectural Components

The architecture model consists of eight modules, each responsible for a specific function:

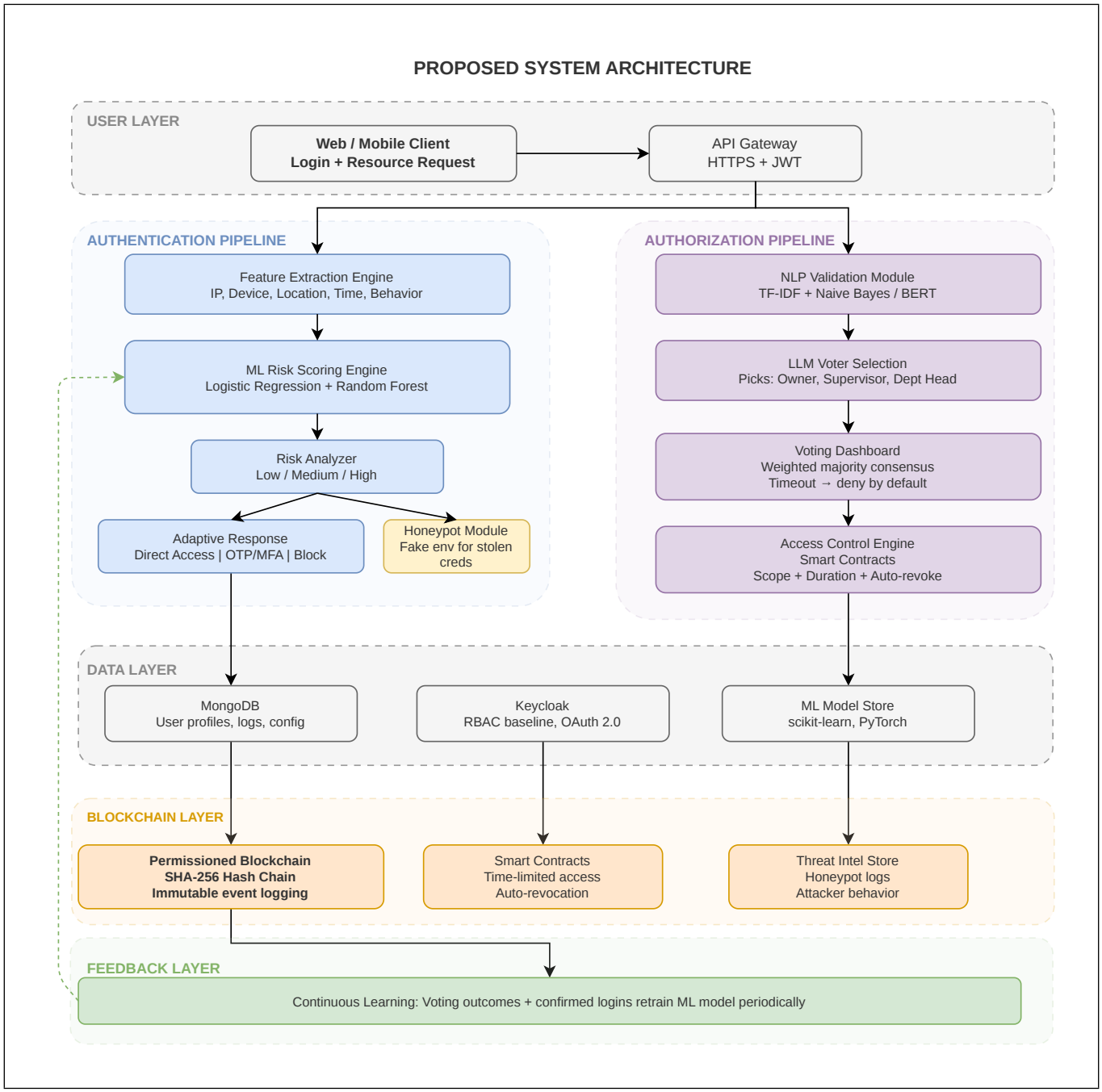


Fig. 3. System architecture showing authentication and authorization pipelines with blockchain audit layer.

- **User Module:** Captures credentials and contextual data over HTTPS.
- **Feature Extraction Engine:** Transforms raw signals into the structured feature vector X.
- **Risk Scoring Engine:** Executes the trained ensemble classifiers for real-time inference.
- **Risk Analyzer:** Applies threshold logic for three tier classification(low/ medium/ high).
- **NLP Validation Module:** Processes free text justifications through the two tier classification pipeline.
- **Voting System:** Manages LLM based reviewer selection, notification, vote collection, and weighted consensus.
- **Blockchain Audit Layer:** Writes hashed blocks and manages smart contract life-cycle.
- **Honeypot Module:** Redirect of stolen credential sessions into the isolated deception environment and captured attacker behavior in a separate threat intelligence chain.

Processing behavioral and geo location data raises compliance requirements under the GDPR and India's Digital Personal Data Protection Act (2023). The design addresses this

TABLE IV
TECHNOLOGY STACK AND IMPLEMENTATION TOOLS

Layer	Technology	Rationale
Backend	Python / Flask	ML integration, rapid API
ML Models	scikit-learn, PyTorch	Ensemble training
NLP	spaCy, NLTK, HuggingFace	Preprocessing + BERT
Frontend	ReactJS	Dashboard, voter UI
Database	MongoDB	Flexible schema
IAM	Keycloak	RBAC, OAuth 2.0
Blockchain	SHA-256 / Hyperledger	Tamper-proof logging
Contracts	Solidity / Hyperledger	Auto-revoke access
Honeypot	Docker containers	Isolated fake env

through data minimization and support for deletion requests. Blockchain writes are restricted to critical events to manage storage costs. The selection of lightweight classifiers over deep neural architectures reflects a deliberate latency accuracy trade-off: the expected accuracy gap is 1–3 percentage points, while the latency reduction is approximately 4x [20]. Bias mitigation is addressed through stratified sampling and periodic audits of false positive rates across geographic regions and device categories [21]. Regular audits are planned to ensure the model does not disproportionately flag users from specific geographic regions or those using less common device configurations.

V. EXPECTED SYSTEM BEHAVIOR

The framework is at the design and architectural validation stage. This section presents expected performance derived from design specifications and published benchmarks of individually comparable components.

A. Risk Scoring Performance

Based on accuracy ranges reported by Wiefling et al. [3], Picard and Pierre [9], and Fereidouni et al. [10], the risk scoring model is projected to achieve 85–92% accuracy on adequately representative datasets. The expected false positive rate is moderate, concentrated on first-time device and location combinations that lack an established baseline.

B. NLP Classification Performance

The TF-IDF + Naive bayes classifier is projected to achieve approx 83% overall accuracy, with precision of $\sim$0.81 and recall of $\sim$0.85 for the suspicious class. Activation of the BERT fallback for posterior probabilities below $\beta = 0.65$ is expected to raise combined accuracy to $\sim$89%.

C. Blockchain and Voting Performance

Write latency on the permissioned blockchain is expected to be below 500ms per event, acceptable given that logging occurs asynchronously. The active learning feedback loop from voting outcomes to model retraining is expected to progressively reduce escalation volume over successive retraining cycles.

TABLE V
EXPECTED RISK SCORES AND SYSTEM ACTIONS BY SCENARIO

Scenario	Exp. S	Action
Known device, normal time	0.05–0.10	Direct access
Known device, unusual time	0.25–0.35	Access or OTP
New device, familiar loc.	0.40–0.50	OTP required
New device, foreign IP	0.75–0.85	Block / strict MFA
Multiple fails + unknown	0.85–0.95	Lockout + alert
VPN on, known device	0.30–0.40	OTP required
Correct pwd + foreign IP	0.85–0.95	Honeypot redirect

D. Honeypot Effectiveness

In simulated stolen credential scenarios where the risk score exceeds 0.85 with valid credentials, the system is expected to redirect approximately 80% of such sessions to the honeypot environment. The remaining 20% fall in the 0.70–0.85 range and are handled through standard blocking. Simulated attackers are projected to spend 15–20 minutes in the honeypot on average before disconnecting, providing meaningful intelligence per incident about targeted resources, navigation patterns, and exfiltration attempts.

TABLE VI
DESIGN VALIDATION CRITERIA AND EXPECTED OUTCOMES

Criterion	Expected Outcome
ML model accuracy	85–92% (literature benchmarks)
Inference latency	$<$ 200 ms per authentication
NLP accuracy (primary)	$\sim$83% (TF-IDF + Naive Bayes)
NLP accuracy (BERT)	$\sim$89% (fallback activated)
Log integrity	SHA-256 hash-chain verification
Access revocation	Automatic via smart contract
Honeypot redirect rate	$\sim$80% of stolen-cred cases
Honeypot engagement	15–20 min avg attacker session

VI. DISCUSSION

A. Contributions

The principal contribution is the integration of five individually established capabilities ML-based adaptive risk scoring, NLP-driven justification validation, LLM-assisted human-in-the-loop authorization, blockchain-backed immutable audit logging, and honeypot-based deception for stolen credential scenarios into a unified IAM framework under Zero Trust principles. As Table I demonstrates, no published system offers all five capabilities within a single architecture. The hybrid decision model automated handling for unambiguous

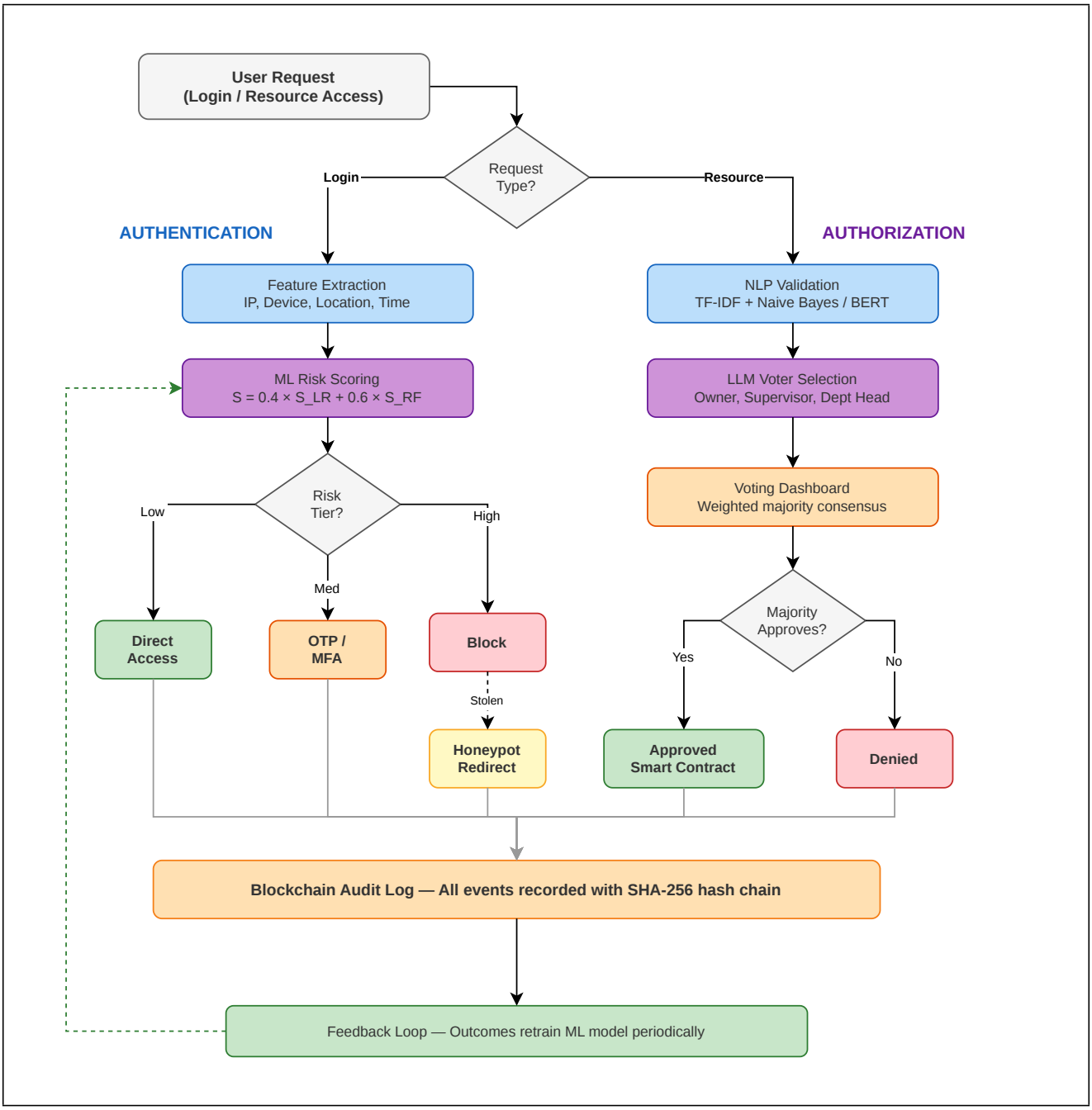


Fig. 4. End-to-end system flow showing both authentication and authorization pipelines.

cases, human escalation for uncertain ones, and deception-based intelligence gathering for confirmed attacks represents a pragmatic balance between speed, thoroughness, and proactive threat response.

B. Limitations

Several limitations warrant acknowledgment. The framework has not been implemented in a production environment; performance projections are derived from published benchmarks and require empirical validation. ML model performance is contingent on training data quality; models trained on narrow datasets may exhibit blind spots. The blockchain layer introduces storage overhead. The voting mechanism introduces latency. The current design evaluates risk at two discrete points (login and resource request) rather than continuously during sessions. The honeypot module adds infrastructure complexity and requires careful network isolation to avoid creating new attack surfaces. Behavioral monitoring raises privacy concerns that any deployment must address through consent mechanisms and data minimization practices [21].

C. Comparison with Existing Approaches

Compared to standalone RBA systems [3], [9], the proposed framework extends adaptive authentication to resource-level authorization and adds deception-based threat intelligence. Compared to blockchain access control systems [16], [18], it introduces context-aware decision-making and adaptive risk scoring. Compared to LLMAC [19], it includes quantitative risk scoring, a voting governance mechanism, an immutable audit trail, and a honeypot layer for stolen credential scenarios. The proposed framework is, to the best of our knowledge, the first to unify all five capabilities.

VII. Conclusion and Future Work

This paper proposed a framework for adaptive identity and access management integrating machine learning, large language models, blockchain technology, and honeypot-based deception under Zero Trust principles. The paper presented the complete design, modular architecture, mathematical formulations for risk scoring and anomaly detection, and an expected performance analysis grounded in published benchmarks. The honeypot module introduces a proactive dimension to the framework, converting confirmed stolen-credential attacks into intelligence-gathering opportunities rather than simply blocking them.

Future work includes: implementation of the proposed framework followed by empirical validation on realistic datasets; integration of SHAP-based explainable AI for transparent risk decision attribution; enhancing the honeypot with LLM-generated synthetic documents to make the deception harder for sophisticated attackers to detect; continuous session-level authentication using behavioral biometrics [11], [12]; migration of the blockchain to a distributed permissioned network; incorporation of federated learning for privacy-preserving behavioral profile construction [20], [21]; and integration with enterprise IAM platforms such as Keycloak [22].

A longer-term direction involves extending the LLM component from voter selection to automatic security policy translation, where the model reads organizational policy documents and generates enforceable access control rules while flagging contradictions and ambiguities.

References

[1] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, and C. E. Youman, "Role-based access control models," *IEEE Computer*, vol. 29, no. 2, pp. 38–47, 1996.

[2] V. C. Hu, D. Ferraiolo, and D. Kuhn, "Assessment of access control systems," NIST Interagency Report 7316, 2017.

[3] S. Wiefling, M. Dürmuth, and L. Lo Iacono, "Pump up password security! Evaluating and enhancing risk-based authentication on a real-world large-scale online service," *ACM Trans. Privacy Security*, 2022.

[4] M. Zyskind, O. Nathan, and A. Pentland, "Decentralizing privacy: Using blockchain to protect personal data," in *Proc. IEEE S&P Workshops*, 2015, pp. 180–184.

[5] Y. Liu, K. Wang, Y. Lin, and W. Xu, "Blockchain-based identity management systems: A survey," *J. Network Comput. Appl.*, vol. 166, 2020.

[6] K. Sharma and R. Gupta, "Adaptive multi-factor authentication for secure systems," *Comput. Security*, vol. 108, 2022.

[7] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero trust architecture," NIST SP 800-207, 2020.

[8] S. Wiefling et al., "RBA login dataset," GitHub, 2022. [Online]. Available: https://github.com/das-group/rba-dataset

[9] G. Picard and S. Pierre, "RLAuth: A risk-based authentication system using reinforcement learning," *IEEE Access*, 2023.

[10] H. Fereidouni et al., "F-RBA: A federated learning-based framework for risk-based authentication," arXiv preprint arXiv:2412.12324, 2024.

[11] A. F. Baig and S. Eskeland, "Security, privacy, and usability in continuous authentication: A survey," *Sensors*, vol. 21, no. 17, 2021.

[12] M. Frank, R. Biedert, E. Ma, I. Martinovic, and D. Song, "Touchalytics: On the applicability of touchscreen input as a behavioral biometric," *IEEE Trans. Inf. Forensics Security*, vol. 8, no. 1, 2013.

[13] J. Kindervag, "Build security into your network's DNA: The zero trust network architecture," Forrester Research, 2010.

[14] Y. Wang et al., "AU-ZTAC: Attribute and user trust score-based zero trust access control in IoV," *Electronics*, vol. 12, no. 23, 2023.

[15] Google, "BeyondCorp: A new approach to enterprise security," Google Whitepaper, 2014.

[16] X. Hu et al., "N-Accesses: A blockchain-based access control framework for IoT," *Sensors*, vol. 23, no. 20, 2023.

[17] R. Patel, S. Mehta, and A. Verma, "Context-aware security decision making using large language models," in *Proc. IEEE Int. Conf. Artificial Intelligence Security*, 2023.

[18] H. Tawfik et al., "ACHealthChain: A blockchain-based access control framework for healthcare data," *Scientific Reports*, vol. 15, 2025.

[19] S. N. Zisad, "LLMAC: A global and explainable access control framework with LLM," arXiv preprint arXiv:2602.09392, 2026.

[20] T. Hastie, R. Tibshirani, and J. Friedman, *The Elements of Statistical Learning*. New York, NY, USA: Springer, 2009.

[21] C. Dwork, "Differential privacy," in *Proc. ICALP*, 2006.

[22] Red Hat, "Keycloak documentation," 2023. [Online]. Available: https://www.keycloak.org

[23] L. Spitzner, *Honeypots: Tracking Hackers*. Boston, MA, USA: Addison-Wesley, 2003.